# ADR 0004: Own JWT authentication with guest accounts

| | |
|---|---|
| Status | Accepted as the target; the MVP implements the same behaviour on today's backend |
| Date | 2026-10-19 |
| Related | `03-system-architecture.md` sections 6 and 7, `05-api-design.md` section 2 |

## Context

Today no route checks who the caller is: the app sends `user_id` and the server believes it, and two sign-up paths accept any id. Users start as **guests** and later upgrade to a real account without losing data. User data (closets, orders, taste) lives in our own database, and the guest-to-account flow is custom logic that no hosted service provides.

## Options

1. **A hosted authentication service** (Supabase Auth, Firebase Auth, Auth0): less code for passwords and social login, but a second identity store to keep in sync with our users and guest logic, and per-user pricing.
2. **Own tokens (JWT) with proven libraries**, our own `users` table, and a small set of provider integrations (Google sign-in verification, SMS and email for codes).

## Decision

Option 2.

- Access token 15 minutes, refresh token 30 days with rotation; refresh families live in Redis state so one can be revoked.
- The server reads the user from the token, never from an id in a request.
- Guest start creates a guest user and returns tokens; sign-up **upgrades that same guest** and only if it is a guest; login on a new phone can merge guest data into the account.
- Roles: `guest`, `customer`, `vendor_owner`, `vendor_staff`, `admin`; permissions are checked on the object; unknown or foreign objects return 404.
- Vendor and admin: separate identities and tokens issued by the vendor-admin service (ADR 0007), with their own signing key (audience `vendor`). No shared users with the customer side. Shorter refresh lifetime for vendors (7 days); admins sit behind Cloudflare Access. Vendor-admin to Core commands use HMAC-signed internal calls, not user tokens, and carry the acting user in `X-Actor`.
- Custom `User` model from day one (already in the scaffold); a `social_identities` table so another provider can be added or swapped.
- Rate limits on guest start, login, sign-up and the public application form.

## Consequences

- We own password reset, throttling and token revocation; use libraries and tests for them.
- Phone or email verification codes need an SMS and email provider.
- Switching to a hosted provider later is a migration, not a rewrite, because provider ids live in `social_identities`.

## Revisit when

The team needs enterprise single sign-on, many social providers, or multi-factor authentication quickly.